

Design Secure Infrastructure Architecture

Name	:	JAI KOUSICK T G
Register No.	:	192421367
Batch	:	2024
Degree / Branch	:	B.Tech. Information Technology
Subject	:	DevSecOps Engineering and Application Security
Subject Code	:	CSA5802

1. Objective

The objective of this assessment is to design an original, professional-grade secure infrastructure architecture that clearly demonstrates defense-in-depth principles. The architecture identifies distinct network security zones, the trust boundaries between them, the end-to-end data flow of a typical user transaction, and the security controls (IAM, encryption, monitoring/logging, and secure communication) applied at each layer of the infrastructure.

2. Tools Used

The architecture was authored as machine-generated, editable diagram source (Graphviz DOT notation, which follows the same declarative node/edge grammar philosophy as DiagrammeR) and additionally exported as an editable **draw.io (.drawio / mxGraph XML)** source file so it can be opened, resized, and further edited directly in diagrams.net (draw.io). Both the editable source file and this final exported PDF are being submitted together as instructed.

3. Secure Infrastructure Architecture Diagram

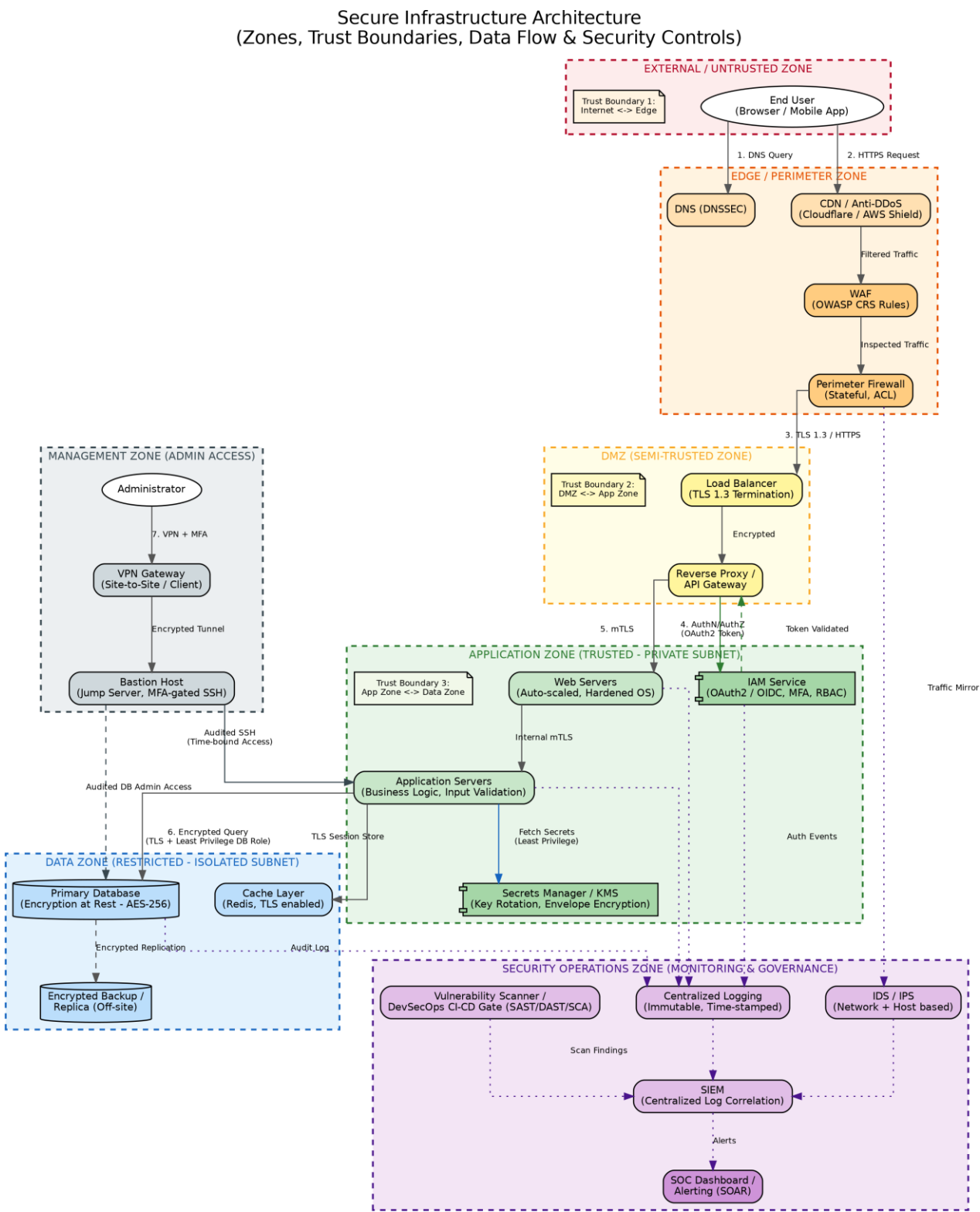


Figure 1: Secure infrastructure architecture showing network zones, trust boundaries, data flow paths, and security controls.

4. Network Zones and Trust Boundaries

External / Untrusted Zone

Represents the public Internet and end-user devices (browser / mobile app). No inherent trust is placed on traffic originating here. This zone is separated from the rest of the infrastructure by **Trust Boundary 1**.

Edge / Perimeter Zone

First line of defense: DNS with DNSSEC, a CDN with anti-DDoS protection, a Web Application Firewall (WAF) enforcing OWASP Core Rule Set policies, and a stateful perimeter firewall with access control lists (ACLs). All inbound traffic is filtered and inspected here before being allowed further.

DMZ (Semi-Trusted Zone)

Hosts the Load Balancer (which terminates TLS 1.3) and the Reverse Proxy / API Gateway. This zone brokers all traffic between the untrusted edge and the trusted internal application zone, forming **Trust Boundary 2**.

Application Zone (Trusted - Private Subnet)

Contains the web tier, application tier, the IAM service (OAuth2/OIDC, MFA, RBAC) and the Secrets Manager/KMS. Placed in a private subnet with no direct Internet route; all requests must pass IAM authentication/authorization first. Separated from the data zone by **Trust Boundary 3**.

Data Zone (Restricted - Isolated Subnet)

The most sensitive zone, housing the primary database (encrypted at rest with AES-256), an encrypted off-site backup/replica, and the Redis cache layer (TLS enabled). Access is restricted to the application tier and audited administrative access only.

Security Operations Zone (Monitoring & Governance)

A cross-cutting zone containing the SIEM, IDS/IPS, centralized immutable logging, a DevSecOps CI/CD security gate (SAST/DAST/SCA vulnerability scanning), and a SOC dashboard with SOAR-based alerting. It receives telemetry from every other zone without participating in the primary transaction data flow.

Management Zone (Admin Access)

Isolated administrative path consisting of a VPN gateway and an MFA-gated bastion host. All administrator access to application or data zone resources is tunnelled, authenticated with MFA, time-bound, and fully audited.

5. Security Controls Summary

Control Category	Implementation in this Architecture
Identity & Access Management (IAM)	OAuth2 / OIDC based IAM service issuing tokens validated at the Reverse Proxy / API Gateway; Multi-Factor Authentication (MFA); Role-Based Access Control (RBAC); least-privilege database roles; MFA-gated bastion host for administrative access.
Encryption	TLS 1.3 termination at the Load Balancer; internal mutual TLS (mTLS) between web, application and gateway tiers; AES-256 encryption at rest for the primary database and backups; TLS-enabled Redis cache; envelope encryption and automated key rotation via a dedicated Secrets Manager / KMS.
Monitoring & Logging	Centralized, immutable, time-stamped logging from web, application, IAM and database layers; network and host-based IDS/IPS with mirrored perimeter traffic; SIEM correlation of all log and alert sources; SOC dashboard with SOAR-driven alerting; DevSecOps CI/CD gate performing SAST, DAST and SCA scanning with findings fed into the SIEM.
Secure Communication Paths	All external traffic enforced over HTTPS/TLS 1.3; East-West traffic secured via mTLS; administrative access routed only through an encrypted VPN tunnel to a bastion host; database replication encrypted in transit.
Network Segmentation	Seven distinct zones (External, Edge, DMZ, Application, Data, Security Operations, Management) with three explicit trust boundaries preventing direct access from lower-trust to higher-trust zones; private/isolated subnets for application and data tiers.
Perimeter Defense	DNSSEC, CDN-based anti-DDoS protection, Web Application Firewall (OWASP CRS), and a stateful perimeter firewall with ACLs filtering all inbound traffic before it reaches the DMZ.

6. End-to-End Data Flow Walkthrough

1. The end user resolves the application domain via DNSSEC-protected DNS, then issues an HTTPS request that is first absorbed by the CDN / anti-DDoS layer.
2. Filtered traffic passes through the WAF (OWASP CRS rules) and the stateful perimeter firewall before being allowed into the DMZ.
3. The Load Balancer terminates TLS 1.3 and forwards the request to the Reverse Proxy / API Gateway.
4. The API Gateway calls the IAM service to authenticate and authorize the request (OAuth2 token issuance and validation) before any traffic is allowed into the trusted Application Zone.
5. Once authorized, traffic reaches the Web Servers over mTLS, which hand off business logic processing to the Application Servers over internal mTLS.
6. The Application Servers retrieve credentials/keys from the Secrets Manager/KMS under least-privilege access, then issue an encrypted, least-privilege query to the Primary Database and/or the TLS-secured Redis cache.
7. The database asynchronously replicates to an encrypted, off-site backup for resilience.
8. In parallel, every tier (edge firewall, web, application, IAM, database) streams logs and events to centralized logging and IDS/IPS sensors, which feed the SIEM. The SIEM correlates events and raises alerts on the SOC dashboard.
9. Administrators never connect directly to application or data resources; they authenticate with MFA over a VPN tunnel to a bastion host, from which all sessions to the Application Servers or Database are time-bound and fully audited.

7. Conclusion

This architecture demonstrates a defense-in-depth secure infrastructure design suitable for a modern web/API-based application. By clearly separating network zones with explicit trust boundaries, enforcing IAM at every hop into a more trusted zone, encrypting data both in transit (TLS 1.3 / mTLS) and at rest (AES-256), and continuously monitoring all tiers through a centralized SIEM/SOC pipeline integrated with a DevSecOps CI/CD security gate, the design satisfies the confidentiality, integrity, and availability requirements expected of a production-grade secure system.